

PRODUCT REQUIREMENTS DOCUMENT

QMS — Quality Management System

Version 1.0 | Date: Sep 2026 | Status: In Production (v1)

1. Overview

QMS is a web-based quality management system that lets an organization manage five core quality record streams — **Documents**, **CAPAs**, **Non-conformances**, **Audits**, and **Training** — through a configurable approval workflow, plus **Committees** for managing working groups and their tasks.

It is role-driven: each user (profile) sits in a reporting hierarchy, and every action — view, create, assign, submit, approve, revise — is authorized against that hierarchy. The Director operates in **monitor-only** mode (view + approve + revise as final authority, no create/assign/committee management), while a Deputy Director performs operational actions on behalf of leadership.

2. Goals & Success Criteria

- **G1 — Traceable quality records:** every record has a status lifecycle and a full history (who changed what, when, with which comment).
- **G2 — Correct authorization:** no user can view, edit, approve, or assign records outside their scope; enforced on both UI and API.
- **G3 — Monitor-only top authority:** the Director sees everything and holds final approval, but cannot create or assign work — separation of duties.
- **G4 — Committee workflow:** committees with members, heads, and tasks; task assignment restricted to committee managers and heads.
- **G5 — Notifications & email:** in-app notifications for all key events and optional email delivery via Resend.
- **G6 — Admin capabilities:** team management (including email editing), committee-permission grants, and leadership succession.
- **Success criteria:** all module workflows operate end-to-end in production; authorization rules verified on both sides; build, lint, and type-check pass.

3. Personas & Roles

Role	Dashboards role	Create/Assign	Approve/Revise	Manage committees	Who
Director (top authority)	top-authority	No (monitor-only)	Yes (final)	No	System admin: team, permissions, succession, test email

Deputy Director	team-lead	Yes	Yes	Yes	Operates record + committee workflows
Quality / Operations Lead	team-lead	Yes	Yes	Flag-based	Owns a function, has subordinate owners
Process Owner	process-owner	Yes	Yes (manager chain)	No	Owns a process, has staff
Analyst / Tech / Specialist	staff	Yes	No	No	Executor of record work

Reporting hierarchy (seeded example)

Alicia Reed (Director) ← Marcus Webb (Deputy) ← Mason Lee (QA Lead) / Priya Shah (Ops Lead) ← Process Owners ← staff.

4. Functional Requirements

FR-1 Authentication & Account

- FR-1.1 Email + password login (NextAuth credentials strategy, JWT sessions).
- FR-1.2 Register with generated credentials; only *active* profiles can sign in.
- FR-1.3 Forgot/reset password using expiring, single-use hashed reset tokens.
- FR-1.4 Unauthenticated users redirected to `/login` with a callback URL; protected pages enforced by proxy and per-API auth.

FR-2 Record Modules (5 shared modules)

Module	Entity fields (beyond base)	Typical statuses
documents	title, revision, status	Draft, Pending, Approved
capa	title, priority, dueDate	Draft, In progress, Done, Approved, Overdue...
nonconformances	title, source, severity, date	Draft, Pending, Approved / High-Medium-Low
audits	title, date	Draft, Pending, Approved
training	employee, course, dueDate	Draft, Pending, Approved / Not started, Active

- FR-2.1 Users can view records within their scope (self + all subordinates, recursively).
- FR-2.2 Users **without** monitor-only can create records and assign them only to direct report(s) within their hierarchy.
- FR-2.3 The assignee can edit/submit; their manager chain (upward) can approve or request revision.
- FR-2.4 Status transitions: Create → Draft; Submit → Pending; Approve → Approved; Revise → back to Draft.

- FR-2.5 Every transition writes a `RecordHistory` entry; comments attach to any record.
- FR-2.6 Soft-delete (`deletedAt`) hides records without destroying data; deleted records are not found.
- FR-2.7 Monitor-only (Director) is rejected with `403` on create/assign and hidden UI on create pages.

FR-3 Committees

- FR-3.1 Create/delete committees; add members with a role — *head* or *member*.
- FR-3.2 Assign tasks to members (title, description, due date, status workflow assigned → *in_progress* → *submitted* → *approved*).
- FR-3.3 Task assignment restricted to committee managers (flag-based) or the committee head.
- FR-3.4 Only the top authority can grant the committee-management permission to another user.

FR-4 Dashboard & Reporting

- FR-4.1 Dashboard scales by role: team-rollup cards (open CAPAs/NCRs/audits, overdue training), module list, and per-person progress.
- FR-4.2 A "New record" button only when permitted (monitor-only excluded).
- FR-4.3 Per-user notifications with read/unread state and deep links.

FR-5 Notifications & Email

- FR-5.1 In-app notifications created for: task assigned, superior assignment, submission for review, approval, revision needed.
- FR-5.2 Optional email via Resend for the same events (turned on when `RESEND_API_KEY` is set).
- FR-5.3 Emails resolve recipient by profile *email* field, editable in Team admin.

FR-6 Admin

- FR-6.1 Team page: view profiles, edit each profile's email, add new users.
- FR-6.2 Grant/revoke committee-management permission (top authority only).
- FR-6.3 Initiate leadership succession (reassign reportsTo).
- FR-6.4 Send a test email to verify email configuration.
- FR-6.5 Change own password.

5. Non-Functional Requirements

Area	Requirement
Security	Password hashing, no passwordHash exposure in APIs, secret keys in env only, JWT signing, authorization enforced server-side (never trust the UI).
Performance	Server-rendered pages, light client state; dashboard reads are scoped to viewer to avoid loading unrelated data.

Reliability	Every API validates auth + permission before acting; graceful 403/404 responses; email failures never break the primary action.
Portability	PostgreSQL (Neon) via Prisma; Node 20+; deployable to Vercel with zero-config env vars.
Accessibility	Semantic HTML, visible focus states, accessible labels on forms.
Compatibility	Modern evergreen browsers (Chrome, Edge, Firefox, Safari).

6. Release scope & out of scope

In scope v1: all sections FR-1...FR-6 above.

Out of scope (future): multi-tenant organizations, SSO/SAML, document file attachments, scheduling/calendar views, audit trails per-field, API tokens, analytics export.

7. Open questions / risks

- Email deliverability depends on a verified Resend domain; with *onboarding@resend.dev* only the account owner's address receives mail.
- Production secrets must be rotated before wide rollout (current values were shared in a local session).
- Regulatory audit support (21 CFR Part 11 / ISO 9001) not yet formally mapped to UI screens.